

HOST & NETWORK

VULNERABILITY ASSESSMENT REPORT

Isolated Lab Environment — Network Reconnaissance & Service Triage

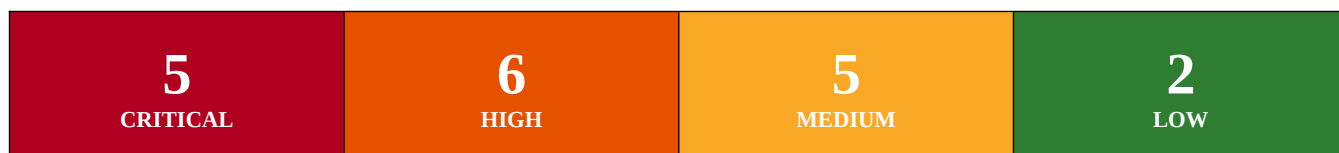
Prepared By	Uzair Ahmed
Student ID	B4/963
Target Scope	192.168.56.102 (isolated internal test VM)
Assessment Type	Authorized internal vulnerability assessment
Tools Used	Nmap 7.98 (-sV -sC / --script vuln), Nikto v2.6.0, Searchsploit
Assessment Window	18–19 August 2026
Report Classification	Internal / Lab Use — Not for production disclosure

1. Executive Summary

This assessment was carried out against an isolated internal lab virtual machine (192.168.56.102) as part of Task 2 of the internship program: a structured host and network vulnerability assessment. The objective was to identify structural service-configuration flaws using industry-standard reconnaissance and vulnerability-mapping tools, then triage the resulting findings by severity.

A full TCP port scan combined with Nmap's service/version detection, default script set, and the dedicated vulnerability-scanning script category (`--script vuln`) enumerated 20 open services. Nikto was additionally run against the web service on port 80 to surface application-layer misconfigurations, and Searchsploit was used to check public exploit availability for the identified service versions.

The target exhibits a very high-risk profile: multiple services carry known, publicly exploitable backdoors or remote-code-execution flaws (vsFTPD 2.3.4, UnrealIRCd, Java RMI, legacy r-services), several core components are a decade or more out of date (Apache 2.2.8, PHP 5.2.4, MySQL 5.0), and the web application layer exposes SQL injection and CSRF weaknesses across bundled training applications. The severity breakdown below summarizes the 18 consolidated findings.



2. Scope & Methodology

Scope

Testing was restricted to a single host, 192.168.56.102, within an isolated VirtualBox host-only network segment. No external or production systems were in scope.

Tools & Commands

- Nmap 7.98 — `nmap -sV -sC -p 1-1000 -T4 --min-rate 1000 192.168.56.102` (service/version + default script sweep)
- Nmap 7.98 — `nmap -sV --script vuln -oN nmap_CVE_Report.txt 192.168.56.102` (targeted CVE / vulnerability scripts)
- Nikto v2.6.0 — `nikto -h http://192.168.56.102` (web server misconfiguration & CVE scan)
- Searchsploit — offline Exploit-DB lookups against identified service versions

Process

- Enumerate open ports, running services, and versions across the full port range.
- Cross-reference service banners and Nmap NSE vulnerability scripts against known CVEs.
- Run Nikto against the web service to surface application/config-level issues.
- Check Exploit-DB via Searchsploit for public proof-of-concept exploits.
- Consolidate and triage all findings into Critical / High / Medium / Low severity.

3. Port & Service Inventory

The table below summarizes every open port identified by the Nmap scan, the detected service/version, and a short risk note carried forward into the detailed findings.

Port	Service	Version / Banner	Notes
21	ftp	vsftpd 2.3.4	Backdoored — CVE-2011-2523
22	ssh	OpenSSH 4.7p1 (Debian)	Outdated; enumeration exploits public
23	telnet	Linux telnetd	Cleartext remote access
25	smtp	Postfix smtpd	POODLE / Logjam TLS issues
53	domain	ISC BIND 9.4.2	Version disclosure
80	http	Apache 2.2.8 (Ubuntu) DAV/2	EOL, multiple app-layer flaws
111	rpcbind	RPC #100000	Exposes NFS/mountd/nlockmgr endpoints
139/445	netbios-ssn	Samba smbd 3.0.20	Signing disabled
512/513/514	exec/login/shell	rexec / rlogind / rshd	Legacy unauthenticated r-services
1099	java-rmi	GNU Classpath grmiregistry	RMI classloader RCE
1524	bindshell	Metasploitable root shell	Direct root shell
2049	nfs	NFS 2-4	Exported shares
2121	ftp	ProFTPD 1.3.1	Known historic RCE variants
3306	mysql	MySQL 5.0.51a	EOL database version
5432	postgresql	PostgreSQL 8.3.0-8.3.7	CCS Injection (CVE-2014-0224)
5900	vnc	VNC protocol 3.3	Weak legacy authentication
6000	X11	access denied	Service exposed, access restricted
6667	irc	UnrealIRCd	Trojaned backdoor build
8009	ajp13	Apache JServ Protocol v1.3	AJP exposure (Ghostcat-class risk)
8180	http	Apache Tomcat/Coyote 1.1	CSRF findings, Slowloris

```

(uzair1453@kali)-[/]
$ nmap -sV -sC -p 1-1000 -T4 --min-rate 1000 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-19 05:53 -0400
Nmap scan report for 192.168.56.102
Host is up (0.00097s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.56.101
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
| vsFTPD 2.3.4 - secure, fast, stable
| End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTA
TUSCODES, 8BITIME, DSN

```

Figure 1 — Nmap -sV -sC scan: initial ports (21/tcp–25/tcp) with FTP anonymous login and SSH host keys.

```

Host script results:
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|   System time: 2026-08-19T05:53:34-04:00
|_clock-skew: mean: 1h19m58s, deviation: 2h18m34s, median: -1s
|_smb2-time: Protocol negotiation failed (SMB2)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.74 seconds

```

Figure 2 — Nmap host script results: SMB security mode, OS discovery, and scan completion summary.

4. Triage Prioritization Matrix

Findings are ranked by exploitability and potential impact. Critical items provide direct, unauthenticated remote code execution or shell access and should be remediated first.

Severity	Port / Service	Reference	Description	Recommendation
CRITICAL	21/tcp vsFTPD 2.3.4	CVE-2011-2523	Backdoored vsFTPD build; a crafted login string opens a root shell (uid=0/gid=0), confirmed by Nmap NSE exploit results.	Remove/replace with a patched FTP daemon; disable the service if not required.
CRITICAL	6667/tcp UnrealIRCd	N/A (known trojaned build)	Service fingerprints as a trojaned UnrealIRCd build with a documented remote backdoor.	Remove the binary and reinstall from a verified source, or disable the service.
CRITICAL	1099/tcp Java RMI Registry	N/A (RMI classloader RCE)	Default RMI registry configuration allows loading classes from remote URLs, enabling remote code execution.	Restrict RMI registry to localhost or disable remote class loading.
CRITICAL	512-514/tcp rexec / rlogin / rsh	N/A (legacy r-services)	Unencrypted, weakly-authenticated remote shell services (rexecd, rlogind, rshd) allow trivial remote access.	Disable all r-services; use SSH exclusively for remote administration.
CRITICAL	1524/tcp bindshell	N/A	A root-level bind shell is listening directly on this port, granting instant unauthenticated command execution.	Investigate and remove immediately; treat host as compromised if seen outside a lab.
HIGH	80/tcp Apache 2.2.8 / PHP 5.2.4	Multiple (EOL software)	Both Apache and PHP are end-of-life releases from 2008, missing over a decade of security patches.	Upgrade to a currently supported Apache and PHP release.
HIGH	80/tcp phpMyAdmin	CVE-2003-1418 (info leak)	phpMyAdmin console is reachable without restriction; ChangeLog file leaks server inode data via ETags.	Restrict access by IP/VPN, enforce authentication, and remove unused changelog files.
HIGH	80/tcp DVWA / Mutillidae / TWiki	N/A (App-layer SQLi/CSRF)	Nmap's http-sql-injection and http-csrf scripts flagged numerous parameters across DVWA, Mutillidae and TWiki susceptible to SQL injection and CSRF.	Patch or remove intentionally vulnerable training apps from any non-isolated environment; apply input validation and CSRF tokens.
HIGH	445/139 Samba smbd 3.0.20	N/A (weak SMB config)	Legacy Samba version with SMB message signing disabled by default, enabling relay/MITM attacks.	Upgrade Samba and enforce SMB signing.
HIGH	5900/tcp VNC (protocol 3.3)	N/A (legacy VNC auth)	Very old VNC protocol version with weak authentication support, enabling brute-force or authentication bypass.	Disable VNC or upgrade and enforce strong authentication over an encrypted tunnel.
HIGH	22/tcp OpenSSH 4.7p1	See searchsploit results	Outdated OpenSSH build; public exploit code exists for username enumeration against related version ranges.	Upgrade OpenSSH to the latest stable release.
MEDIUM	25/tcp Postfix (TLS)	CVE-2014-3566 / CVE-2015-4000	SMTP TLS configuration is vulnerable to POODLE and Logjam (export-grade & anonymous Diffie-Hellman ciphers accepted).	Disable SSLv3 and export-grade ciphers; enforce modern TLS with strong DH parameters.
MEDIUM	5432/tcp PostgreSQL 8.3	CVE-2014-0224	SSL/TLS layer is vulnerable to CCS Injection, allowing MITM session hijacking.	Upgrade OpenSSL and PostgreSQL to current patched versions.
MEDIUM	80 / 8180 Apache / Tomcat	CVE-2007-6750	Both web servers are likely vulnerable to Slowloris-style denial-of-service (slow HTTP connections).	Configure connection/request timeouts (e.g. mod_reqtimeout) or place behind a reverse proxy with DoS protections.
MEDIUM	21/tcp vsFTPD	N/A (anonymous access)	Anonymous FTP login is permitted (230 response), exposing the file store without credentials.	Disable anonymous FTP access.
MEDIUM	80/tcp Apache HTTP	N/A (HTTP TRACE / XST)	HTTP TRACE method is enabled, enabling Cross-Site Tracing (XST) attacks against cookies/headers.	Disable the TRACE method in the web server configuration.

Severity	Port / Service	Reference	Description	Recommendation
LOW	80/tcp Apache HTTP	N/A	Directory indexing enabled on /icons/, /doc/ and /test/; missing security headers (CSP, X-Content-Type-Options, HSTS, Referrer-Policy, Permissions-Policy).	Disable directory listing and add the recommended security headers.
LOW	80/tcp PHP	N/A	phpinfo.php and PHP 'easter egg' query strings expose detailed server configuration and version fingerprints.	Remove phpinfo.php from production and disable expose_php in php.ini.

5. Web Application Findings (Nikto)

Nikto's scan against port 80 completed in 384 seconds, sending 8,242 requests and reporting 30 items. Alongside the outdated Apache/PHP stack, it identified exposed phpMyAdmin and phpinfo.php endpoints, browsable directories, an active HTTP TRACE method (XST risk), and a full set of missing modern security headers (CSP, X-Content-Type-Options, HSTS, Referrer-Policy, Permissions-Policy).

```
(uzair1453@kali)~$ nikto -h http://192.168.56.102
- Nikto v2.6.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-08-18 18:22:40 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates:
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HT
TP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTT
P/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Hea
ders/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/He
aders/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/
HTTP/Headers/Strict-Transport-Security
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names.
The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://ex
change.xforce.ibmcloud.com/vulnerabilities/8275
```

Figure 3 — Nikto scan startup and initial findings: outdated Apache/PHP versions and missing security headers.

6. Exploit Availability (Searchsploit)

To gauge real-world exploitability, identified service versions were cross-checked against the offline Exploit-DB mirror via Searchsploit. Public, ready-to-use exploit code exists for three of the identified services, reinforcing the Critical/High ratings assigned above.

Service	Exploit-DB Title	Path
OpenSSH 4.7p1	OpenSSH 2.3 < 7.7 - Username Enumeration	linux/remote/45233.py, 45210.py
OpenSSH 4.7p1	OpenSSH < 7.7 - User Enumeration (2)	linux/remote/45939.py
OpenSSH 4.7p1	OpenSSH < 6.6 SFTP - Command Execution	linux_x86-64/remote/45000.c, linux/remote/45001.py
vsftpd 2.3.4	vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4	vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb
Linux telnetd	netkit-telnet-0.17 telnetd (Fedora 31) - RCE	linux/remote/48170.py
Linux telnetd	TelnetD encrypt_keyid - Function Pointer Overwrite	linux/remote/18280.c

```
(uzair1453@kali)-[~]
$ searchsploit OpenSSH 4.7p1
```

Exploit Title	Path
OpenSSH 2.3 < 7.7 - Username Enumeration	linux/remote/45233.py
OpenSSH 2.3 < 7.7 - Username Enumeration (PoC)	linux/remote/45210.py
OpenSSH < 6.6 SFTP (x64) - Command Execution	linux_x86-64/remote/45000.c
OpenSSH < 6.6 SFTP - Command Execution	linux/remote/45001.py
OpenSSH < 7.4 - 'UsePrivilegeSeparation Disabled' Forwarded Unix Domain Sockets Privilege E	linux/local/40962.txt
OpenSSH < 7.4 - agent Protocol Arbitrary Library Loading	linux/remote/40963.txt
OpenSSH < 7.7 - User Enumeration (2)	linux/remote/45939.py

Figure 4 — Searchsploit results for OpenSSH 4.7p1.

```
(uzair1453@kali)-[~]
$ searchsploit vsftpd 2.3.4
```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

Figure 5 — Searchsploit results for vsftpd 2.3.4 (confirmed backdoor exploit).

```
(uzair1453@kali)-[~]
$ searchsploit Linux telnetd
```

Exploit Title	Path
netkit-telnet-0.17 telnetd (Fedora 31) - 'BraveStarr' Remote Code Execution	linux/remote/48170.py
TelnetD encrypt_keyid - Function Pointer Overwrite	linux/remote/18280.c

Shellcode Title	Path
Linux/MIPS (Little Endian) - system(telnetd -l /bin/sh) Shellcode (80 bytes)	linux_mips/27132.txt

Figure 6 — Searchsploit results for Linux telnetd.

7. Recommendations

- Immediately remove or isolate services with confirmed backdoors: vsFTPD 2.3.4, UnrealIRCd, and the bindshell listener on 1524/tcp.
- Disable all legacy r-services (rexec, rlogin, rsh) and enforce SSH-only remote administration.
- Upgrade Apache, PHP, MySQL, PostgreSQL, Samba, and OpenSSH to current, supported releases.
- Restrict or remove phpMyAdmin, phpinfo.php, and directory listings from any externally reachable path.
- Disable SSLv3/export-grade ciphers and enforce modern TLS configurations to close POODLE/Logjam/CCS-Injection gaps.
- Apply CSRF tokens and parameterized queries across the web applications flagged for SQLi/CSRF.
- Add standard security headers (CSP, X-Content-Type-Options, HSTS, Referrer-Policy, Permissions-Policy) and disable the HTTP TRACE method.
- Re-scan after remediation to confirm closure of each finding before promoting any configuration out of the lab environment.

8. Conclusion

This host — consistent with a deliberately vulnerable training image — presents an extensive attack surface spanning backdoored services, end-of-life software, weak legacy protocols, and unpatched web applications. Five findings are rated Critical due to direct, unauthenticated remote-code-execution paths with public exploits available. The recommendations above are prioritized to close the highest-impact exposures first and should guide remediation sequencing in any environment where equivalent conditions are found outside an isolated lab.